

Área de Conocimiento de Tecnología de la Información y Comunicación

Administración informática

Estudio de casos – políticas TI

Elaborado por: Br. Gerson Antonio Valdivia

Docente: Ing. Martín Loza Romo

18 de agosto, 2026
Managua, Nicaragua

Transformación y Desafíos de Seguridad en "Financiera Progresar"

Marco Normativo, Gobernanza de TI, Políticas de Asignación y Gestión de Riesgo Tecnológico

1. CONTEXTO INSTITUCIONAL

"Financiera Progresar" es una entidad crediticia supervisada que atiende a miles de clientes. Con el propósito de agilizar sus operaciones y modernizar su infraestructura tecnológica, la Junta Directiva autorizó la migración paulatina de sus aplicaciones críticas a entornos virtuales y la subcontratación de un Proveedor de Servicios de Seguridad Administrados (MSSP) para la monitorización de su perímetro de red.

2. DIAGNÓSTICO DE INCIDENTES OPERATIVOS Y DE CONTROL

Incidente A: Estaciones de Trabajo y Uso Aceptable (AUP)

- En la sucursal central, varios colaboradores adquirieron e instalaron aplicaciones ofimáticas y herramientas de descarga de forma autónoma en sus equipos asignados para "agilizar sus reportes semanales".
- Un oficial de crédito conectó una memoria USB personal para sustraer un listado confidencial de clientes a su computadora personal, ocasionando la infección por malware de la red local y la fuga temporal de bases de datos.
- Múltiples auxiliares comparten una misma cuenta de usuario genérica para registrar operaciones en el sistema transaccional con el fin de evitar los bloqueos automáticos de sesión por inactividad.

Incidente B: Adquisiciones No Planificadas y Soporte Técnico Informal

- La jefatura comercial tramitó directamente la compra de diez escáneres especializados contactando a un proveedor sin consultar al Área de Informática. Al recibirse, se detectó que eran incompatibles con el sistema operativo institucional y que en bodega existían equipos idénticos disponibles y desocupados.
- Las solicitudes de soporte técnico se canalizan verbalmente o vía llamadas informales a técnicos de guardia, omitiendo el registro de órdenes de solicitud, el diagnóstico escalonado por niveles y la firma de actas de conformidad.

Incidente C: Externalización de Servicios (Outsourcing) y Gobernanza

- Se contrató a una empresa externa para el desarrollo y alojamiento en la nube de un módulo de cobro mediante un contrato básico sin acuerdos de nivel de servicio (SLA) con penalizaciones, ni custodia del código fuente (*Escrow*).
- El servicio sufrió una caída crítica de 48 horas continuas y el proveedor negó el acceso al equipo de auditoría interna para inspeccionar las bases de datos y registros lógicos.

Bloque 1: Asignación, Uso Aceptable y Soporte Técnico

1. **Perfil de Usuario y AUP:** Yo considero que el gran error fue dejar a los usuarios como administradores de sus propios equipos y no bloquear los puertos USB. Si yo estuviera a cargo, crearía perfiles de usuario basados en el cargo de cada persona (roles) y aplicaría políticas de grupo (GPO) para bloquear automáticamente cualquier instalación de programas y el uso de memorias extraíbles.
2. **Procedimiento Formal de Soporte:** Para mí, el proceso correcto siempre debe empezar obligando al usuario a registrar un ticket en el sistema de Helpdesk (Nivel 1). Si el técnico inicial no puede, yo lo escalaría a un especialista (Nivel 2 o 3). Al resolverlo, pediría que el usuario firme un acta de conformidad para poder cerrar el ticket y dejar constancia en el historial del equipo.

Bloque 2: Adquisición de Tecnología y Principios de Gestión

1. **Flujo Integral de Compras:** Yo pienso que el flujo obligatorio debe ser: 1) justificar técnicamente la necesidad, 2) revisar primero si hay equipos sin usar en bodega, 3) pedir cotizaciones (RFP) y 4) que un comité decida la compra. Opino que la compra de los escáneres violó la eficiencia y el ROI porque se gastó dinero a lo ciego en equipos incompatibles, desperdiciando presupuesto cuando ya tenían aparatos disponibles en el inventario.

Bloque 3: Seguridad Organizacional y Contrataciones Externas

1. **Responsabilidad Institucional en Outsourcing:** Opino que la Junta Directiva está completamente equivocada para quitarse la culpa. Según lo que entiendo de las normas (como la SIBOIF), aunque el banco contrate a un tercero para que opere el sistema, la responsabilidad legal de proteger los datos de los clientes siempre es de la institución financiera y no se puede delegar.
2. **Cláusulas Contractuales Indispensables:** En mi análisis, al contrato le faltaron cuatro cosas vitales que yo hubiera exigido:

SLA: Para obligar al proveedor a cumplir un tiempo mínimo en línea y cobrarle multas si el sistema se cae.

NDA (Confidencialidad): Para proteger legalmente los datos del banco.

Custodia del Código Fuente (Escrow): Para que el banco tenga acceso al código fuente por si la empresa externa quiebra o los abandona.

Derecho de Auditoría: Para que el banco pueda ir a revisar cómo el proveedor maneja la seguridad.

Bloque 4: Gobernanza Multinivel y Factor Humano

1. **Políticas Multinivel:** Para poner orden, yo clasificaría las medidas correctivas de esta manera:
 - Estratégico (Junta Directiva):** Deben aprobar las políticas generales de seguridad y las reglas para contratar proveedores.
 - Táctico (Gerencia de TI):** Tienen que escribir la política de uso aceptable (AUP) y definir qué accesos tendrá cada perfil.

Operativo (Soporte Técnico): Son los que deben ir a las computadoras a activar los bloqueos de USB y atender los tickets del día a día.

2. **Principio de No Repudio y Controles Lógicos:** Pienso que usar cuentas genéricas es un peligro porque si alguien hace un fraude, es imposible saber quién de todos fue; por eso se pierde el "no repudio". Mi plan para arreglar esto sería borrar todas las cuentas compartidas, exigir que cada quien use su propia contraseña con doble factor (MFA) y configurar un bloqueo automático de pantalla si dejan la computadora sola por unos minutos